

# Quantitative Risk Assessment

Asset Risk Register, ALE Modeling, and Risk Heatmap (NIST SP 800-30)

SecurityGroup101 | Enterprise GRC Program  
Prepared By: Maxine Jones, GRC Analyst | Reviewed By: IT Risk Manager  
Version 1.0 | Classification: Confidential – Internal Use

## 1. Purpose and Methodology

This assessment applies a quantitative risk methodology aligned with NIST SP 800-30 to prioritize cybersecurity risk across ten critical assets supporting SecurityGroup101's fintech operations. Each asset is scored using Single Loss Expectancy (SLE), the estimated financial impact of a single incident; Annual Rate of Occurrence (ARO), the estimated frequency of occurrence per year; and Annual Loss Expectancy (ALE), calculated as SLE multiplied by ARO. Risk tier is determined from ALE in combination with regulatory exposure and operational criticality.

## 2. Asset Risk Register and ALE Calculations

| Asset                   | Description                                           | SLE         | ARO  | ALE       | Tier   | Primary Threats                                  |
|-------------------------|-------------------------------------------------------|-------------|------|-----------|--------|--------------------------------------------------|
| Customer Data           | Personal, financial, and transactional customer data  | \$1,000,000 | 0.50 | \$500,000 | Tier 1 | Ransomware, data breach, unauthorized access     |
| Employee Workstations   | End-user devices accessing internal/cloud systems     | \$200,000   | 2.00 | \$400,000 | Tier 1 | Malware, phishing, credential theft              |
| Financial Records       | Accounting data, revenue, financial statements        | \$1,500,000 | 0.10 | \$150,000 | Tier 2 | Fraud, tampering, unauthorized changes           |
| Backup Systems          | On-prem and cloud backup infrastructure               | \$600,000   | 0.25 | \$150,000 | Tier 2 | Ransomware, corruption, failed restores          |
| Proprietary Software    | Internal financial analytics and payment applications | \$750,000   | 0.15 | \$112,500 | Tier 2 | Exploitation, IP theft, code tampering           |
| Cloud Storage           | Cloud-based operational and analytical storage        | \$500,000   | 0.05 | \$25,000  | Tier 3 | Misconfiguration, unauthorized access, data loss |
| Development Environment | Non-production systems for testing and development    | \$100,000   | 0.20 | \$20,000  | Tier 3 | Code theft, insider threats, lateral movement    |
| Database Server         | Databases supporting applications and services        | \$50,000    | 0.33 | \$16,665  | Tier 3 | SQL injection, outages, corruption               |
| Email Server            | Corporate email and messaging systems                 | \$30,000    | 0.50 | \$15,000  | Tier 3 | Phishing, BEC, malware delivery                  |
| Website                 | Customer-facing web portal                            | \$75,000    | 0.20 | \$15,000  | Tier 3 | DDoS, defacement, web exploitation               |

Annual Loss Expectancy = Single Loss Expectancy × Annual Rate of Occurrence. Customer Data (\$500,000 ALE) and Employee Workstations (\$400,000 ALE) represent the two highest-priority assets, driven respectively by high-impact regulatory and breach exposure and by high-frequency endpoint compromise.

## 3. Risk Tier Prioritization

| Tier              | Assets                                                                         |
|-------------------|--------------------------------------------------------------------------------|
| Tier 1 – Critical | Customer Data, Employee Workstations                                           |
| Tier 2 – High     | Financial Records, Backup Systems, Proprietary Software                        |
| Tier 3 – Moderate | Cloud Storage, Development Environment, Database Server, Email Server, Website |

## 4. Risk Heatmap

Likelihood is derived from Annual Rate of Occurrence; impact is derived from Single Loss Expectancy and regulatory/business impact. The classification below translates the quantitative model into a qualitative view for executive reporting.

| Asset                   | Likelihood | Impact | Risk Level |
|-------------------------|------------|--------|------------|
| Customer Data           | High       | High   | Critical   |
| Employee Workstations   | High       | Medium | High       |
| Financial Records       | Medium     | High   | High       |
| Backup Systems          | Medium     | High   | High       |
| Proprietary Software    | Medium     | Medium | Medium     |
| Cloud Storage           | Low        | High   | Medium     |
| Development Environment | Low        | Medium | Medium     |
| Database Server         | Medium     | Low    | Moderate   |
| Email Server            | Medium     | Low    | Moderate   |
| Website                 | Low        | Medium | Moderate   |

### Heatmap Interpretation

**Critical (High likelihood / High impact):** Customer Data — the highest priority given financial, regulatory, and reputational impact.

**High (Moderate–High likelihood / High impact):** Employee Workstations, Financial Records, Backup Systems — likely entry points or high-impact assets that can escalate into enterprise-wide incidents.

**Medium (Moderate likelihood or impact):** Proprietary Software, Cloud Storage, Development Environment — indirect risk through lateral movement, misconfiguration, or exposure of sensitive processes.

**Moderate (Lower impact or likelihood):** Database Server, Email Server, Website — lower individual priority but still relevant for monitoring and defense-in-depth.

## 5. Business Impact and Use

This quantitative model supports risk-based prioritization of security controls, alignment of disaster recovery tiering (RTO/RPO) to financial exposure, compliance mapping across NIST, ISO 27001, PCI DSS, and GLBA, and executive-level risk reporting using measurable financial metrics rather than qualitative judgment alone. It directly informs the Disaster Recovery Plan's Tier 1–3 recovery sequencing and the Statement of Applicability's risk-based applicability decisions.